

Brilliance EMS

API Documentation

Base URL: `http://localhost:5000`

Stack: Node.js + Express + MongoDB (Mongoose) + JWT

All protected routes need header: Authorization: Bearer <token>

Roles: candidate | employee | manager | hr | admin

(RN app may send PascalCase: Candidate, Employee, Manager, HR, Admin — both accepted)

Success response shape: { success, message, data }

Error response shape: { success: false, message, errors? }

Database: brillianceDB

Mobile auth flow (Brilliance RN app):

1. RoleSelectionScreen !' pick one of 5 roles
2. Login / SignUp / Forgot always send that role in the body
3. Login fails if password is OK but selected role does not match the account role

0. Health

GET /health

Auth: No auth

Note: Server health check — no body

1. Auth /api/auth

role is required on register, login, forgot-password, verify-otp, and reset-password.

Accepted values: candidate | employee | manager | hr | admin (or Candidate | Employee | Manager | HR | Admin).

POST /api/auth/register

Auth: No auth

Headers: Content-Type: application/json

Body (JSON):

```
{
  "name": "Ali Khan",
  "email": "ali@email.com",
  "password": "secret123",
  "phone": "03001234567",
  "role": "Candidate"
}
```

Note: Creates account with the selected role. Returns { user, token }. If email already exists under another role, returns 409 with that role in the message.

POST /api/auth/login

Auth: No auth

Headers: Content-Type: application/json

Body (JSON):

```
{
  "email": "ali@email.com",
  "password": "secret123",
  "role": "HR"
}
```

Note: Returns { user, token }. If credentials are valid but role mismatches account, returns 403 e.g. "This account is registered as 'employee'. Please select that role to login."

POST /api/auth/forgot-password

Auth: No auth

Headers: Content-Type: application/json

Body (JSON):

```
{
  "email": "ali@email.com",
  "role": "Employee"
}
```

Note: RN Forget step 1. Looks up email + role. Generates 6-digit OTP (10 min). Dev (non-production) returns { otp } in data.

POST /api/auth/verify-otp

Auth: No auth

Headers: Content-Type: application/json

Body (JSON):

```
{
  "email": "ali@email.com",
  "role": "Employee",
  "otp": "482915"
}
```

Note: RN Forget step 2. Validates OTP without consuming it. Returns { verified: true }.

POST /api/auth/reset-password

Auth: No auth

Headers: Content-Type: application/json

Body (JSON):

```
{
  "email": "ali@email.com",
  "role": "Employee",
  "otp": "482915",
  "newPassword": "newSecret123"
}
```

Note: RN Forget step 3. otp required (token alias also accepted). Clears OTP after success.

GET /api/auth/me

Auth: Bearer JWT required

Headers: Authorization: Bearer <token>

Note: Returns current user including role, department, branch, manager.

POST /api/auth/logout

Auth: Bearer JWT required

Headers: Authorization: Bearer <token>

Note: Client should discard token.

POST /api/auth/change-password

Auth: Bearer JWT required

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "currentPassword": "oldPass",
  "newPassword": "newPass123"
}
```

PATCH /api/auth/2fa

Auth: Bearer JWT required

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{ "enabled": true }
```

Note: Flag only — real OTP/SMS later.

2. Employees /api/employees

GET /api/employees

Auth: Bearer JWT required
Roles: employee, manager, hr, admin
Headers: Authorization: Bearer <token>
Query: ?department=&branch=&search=

GET /api/employees/team/mine

Auth: Bearer JWT required
Roles: manager, hr, admin
Headers: Authorization: Bearer <token>

GET /api/employees/:id

Auth: Bearer JWT required
Roles: staff (self / manager of / hr / admin)
Headers: Authorization: Bearer <token>

POST /api/employees

Auth: Bearer JWT required
Roles: hr, admin
Headers: Content-Type: application/json | Authorization: Bearer <token>
Body (JSON):

```
{
  "name": "Sara Ahmed",
  "email": "sara@company.com",
  "password": "ChangeMe123",
  "role": "employee",
  "phone": "03001112233",
  "department": "<deptId>",
  "branch": "<branchId>",
  "manager": "<managerUserId>",
  "designation": "Software Engineer",
  "dateOfJoining": "2026-01-15",
  "address": { "city": "Lahore", "country": "Pakistan" }
}
```

PATCH /api/employees/:id

Auth: Bearer JWT required
Roles: self: phone/address/emergencyContacts | hr/admin: full
Headers: Content-Type: application/json | Authorization: Bearer <token>
Body (JSON):

```
{
  "phone": "03009998877",
  "address": { "city": "Karachi" },
  "emergencyContacts": [
    { "name": "Father", "relation": "father", "phone": "03001110000" }
  ]
}
```

DELETE /api/employees/:id

Auth: Bearer JWT required
Roles: hr, admin
Headers: Authorization: Bearer <token>
Note: Soft delete (isDeleted=true)

POST /api/employees/:id/documents

Auth: Bearer JWT required
Roles: self or hr/admin
Headers: Content-Type: multipart/form-data | Authorization: Bearer <token>
Body (multipart/form-data):
file: <binary>
name: "CNIC"
type: "id"

POST /api/employees/:id/photo

Auth: Bearer JWT required

Roles: self or hr/admin

Headers: Content-Type: multipart/form-data | Authorization: Bearer <token>

Body (multipart/form-data):

photo: <image file>

3. Departments & Branches /api/departments

GET /api/departments

Auth: Bearer JWT required

Roles: staff

Headers: Authorization: Bearer <token>

POST /api/departments

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "name": "Engineering",
  "code": "ENG",
  "description": "Product engineering",
  "head": "<userId>"
}
```

PATCH /api/departments/:id

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{ "name": "Engineering & IT", "isActive": true }
```

DELETE /api/departments/:id

Auth: Bearer JWT required

Roles: hr, admin

Headers: Authorization: Bearer <token>

Note: Deactivates department

GET /api/departments/branches/list

Auth: Bearer JWT required

Roles: staff

Headers: Authorization: Bearer <token>

POST /api/departments/branches

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "name": "Lahore HQ",
  "code": "LHR",
  "city": "Lahore",
  "country": "Pakistan",
  "phone": "042111222333"
}
```

PATCH /api/departments/branches/:id

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{ "city": "Lahore", "isActive": true }
```

DELETE /api/departments/branches/:id

Auth: Bearer JWT required

Roles: hr, admin

Headers: Authorization: Bearer <token>

4. Attendance /api/attendance

POST /api/attendance/clock-in

Auth: Bearer JWT required

Roles: staff

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{ "location": { "lat": 31.52, "lng": 74.35 } }
```

POST /api/attendance/clock-out

Auth: Bearer JWT required

Roles: staff

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "location": { "lat": 31.52, "lng": 74.35 },
  "earlyLeaveReason": "Doctor appointment"
}
```

POST /api/attendance/late-reason

Auth: Bearer JWT required

Roles: staff

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "date": "2026-07-28",
  "reason": "Traffic jam"
}
```

GET /api/attendance/me

Auth: Bearer JWT required

Roles: staff

Headers: Authorization: Bearer <token>

Query: ?from=2026-07-01&to=2026-07-31

GET /api/attendance/team

Auth: Bearer JWT required

Roles: manager, hr, admin

Headers: Authorization: Bearer <token>

Query: ?from=&to=&employeeId=

PATCH /api/attendance/:id/adjust

Auth: Bearer JWT required

Roles: manager, hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "clockIn": "2026-07-28T09:05:00.000Z",
  "clockOut": "2026-07-28T18:00:00.000Z",
  "status": "late",
  "adjustmentNote": "Approved late arrival"
}
```

GET /api/attendance/shifts

Auth: Bearer JWT required

Roles: staff

Headers: Authorization: Bearer <token>

POST /api/attendance/shifts

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "name": "General",
  "startTime": "09:00",
  "endTime": "18:00",
  "graceMinutes": 15
}
```

PATCH /api/attendance/shifts/:id

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{ "graceMinutes": 20 }
```

GET /api/attendance/holidays

Auth: Bearer JWT required

Roles: staff

Headers: Authorization: Bearer <token>

POST /api/attendance/holidays

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "name": "Independence Day",
  "date": "2026-08-14",
  "type": "public"
}
```

5. Leaves /api/leaves

GET /api/leaves/policies

Auth: Bearer JWT required

Roles: staff

Headers: Authorization: Bearer <token>

POST /api/leaves/policies

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "name": "Annual Leave",
  "leaveType": "annual",
  "daysPerYear": 14,
  "carryForward": true,
  "description": "Yearly paid leave"
}
```

PATCH /api/leaves/policies/:id

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{ "daysPerYear": 16, "isActive": true }
```

GET /api/leaves/balances/me

Auth: Bearer JWT required

Roles: staff

Headers: Authorization: Bearer <token>

Query: ?year=2026

POST /api/leaves/balances

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "employee": "<userId>",
  "leaveType": "annual",
  "year": 2026,
  "allocated": 14
}
```

POST /api/leaves/requests

Auth: Bearer JWT required

Roles: staff

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "leaveType": "annual",
  "startDate": "2026-08-01",
  "endDate": "2026-08-03",
  "reason": "Family trip"
}
```

GET /api/leaves/requests/me

Auth: Bearer JWT required

Roles: staff

Headers: Authorization: Bearer <token>

GET /api/leaves/requests

Auth: Bearer JWT required

Roles: manager, hr, admin

Headers: Authorization: Bearer <token>

Query: ?status=pending

PATCH /api/leaves/requests/:id/review

Auth: Bearer JWT required

Roles: manager, hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "decision": "approved",
  "note": "OK",
  "escalateToHr": false
}
```

Note: decision: approved | rejected

6. Payroll /api/payroll

POST /api/payroll/structures

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "employee": "<userId>",
  "basic": 80000,
  "allowances": { "housing": 10000, "transport": 5000, "medical": 2000, "other": 0 },
  "deductions": { "tax": 3000, "providentFund": 4000, "loan": 0, "other": 0 },
  "currency": "PKR",
  "effectiveFrom": "2026-01-01"
}
```

GET /api/payroll/structures/:employeeId

Auth: Bearer JWT required

Roles: staff / hr / admin

Headers: Authorization: Bearer <token>

POST /api/payroll/run

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "month": 7,
  "year": 2026,
  "bonuses": { "<employeeId>": 5000 }
}
```

GET /api/payroll/runs

Auth: Bearer JWT required

Roles: hr, admin

Headers: Authorization: Bearer <token>

GET /api/payroll/payslips/me

Auth: Bearer JWT required

Roles: staff

Headers: Authorization: Bearer <token>

GET /api/payroll/payslips/:id

Auth: Bearer JWT required

Roles: owner or hr/admin

Headers: Authorization: Bearer <token>

7. Performance /api/performance

POST /api/performance/goals

Auth: Bearer JWT required

Roles: staff

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "employee": "<userId optional for self>",
  "title": "Improve API coverage",
  "description": "Add remaining module tests",
  "framework": "kpi",
  "targetValue": 100,
  "currentValue": 40,
  "unit": "%",
  "dueDate": "2026-09-30"
}
```

GET /api/performance/goals

Auth: Bearer JWT required

Roles: staff

Headers: Authorization: Bearer <token>

Query: ?employee=<id>

PATCH /api/performance/goals/:id

Auth: Bearer JWT required

Roles: owner / manager / hr / admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{ "currentValue": 70, "status": "active" }
```

POST /api/performance/reviews

Auth: Bearer JWT required

Roles: manager, hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "employee": "<userId>",
  "period": "2026-H1",
  "status": "draft"
}
```

GET /api/performance/reviews

Auth: Bearer JWT required

Roles: staff

Headers: Authorization: Bearer <token>

Query: ?employee=<id>

PATCH /api/performance/reviews/:id/self-assessment

Auth: Bearer JWT required

Roles: employee (own review)

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{ "selfAssessment": "Completed all assigned OKRs..." }
```

PATCH /api/performance/reviews/:id/complete

Auth: Bearer JWT required

Roles: manager, hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "managerComments": "Strong performer",
  "rating": 4,
  "promotionRecommendation": "none"
}
```

Note: promotionRecommendation: none | promote | demote

8. Training /api/training

GET /api/training/courses

Auth: Bearer JWT required

Roles: staff

Headers: Authorization: Bearer <token>

POST /api/training/courses

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "title": "Workplace Safety",
  "description": "Mandatory safety training",
  "category": "compliance",
  "durationHours": 4,
  "isMandatory": true
}
```

PATCH /api/training/courses/:id

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{ "isActive": true, "durationHours": 5 }
```

POST /api/training/courses/:courseId/enroll

Auth: Bearer JWT required
Roles: staff (self) / manager (team) / hr
Headers: Content-Type: application/json | Authorization: Bearer <token>
Body (JSON):
{ "employee": "<optional userId>" }

GET /api/training/enrollments/me

Auth: Bearer JWT required
Roles: staff
Headers: Authorization: Bearer <token>

PATCH /api/training/enrollments/:id/progress

Auth: Bearer JWT required
Roles: owner or hr/admin
Headers: Content-Type: application/json | Authorization: Bearer <token>
Body (JSON):
{ "progress": 80, "status": "in-progress" }

POST /api/training/enrollments/:id/certificate

Auth: Bearer JWT required
Roles: enrollment owner
Headers: Content-Type: multipart/form-data | Authorization: Bearer <token>
Body (multipart/form-data):
certificate: <pdf/image file>

GET /api/training/reports/completion

Auth: Bearer JWT required
Roles: hr, admin
Headers: Authorization: Bearer <token>

9. Expenses /api/expenses

POST /api/expenses

Auth: Bearer JWT required
Roles: staff
Headers: Content-Type: multipart/form-data | Authorization: Bearer <token>
Body (multipart/form-data):
title: Client lunch
category: meal
amount: 2500
currency: PKR
description: Meeting with client
expenseDate: 2026-07-20
receipt: <file>
Note: category: travel | meal | equipment | training | other

GET /api/expenses/me

Auth: Bearer JWT required
Roles: staff
Headers: Authorization: Bearer <token>

GET /api/expenses

Auth: Bearer JWT required
Roles: manager, hr, admin
Headers: Authorization: Bearer <token>
Query: ?status=pending

PATCH /api/expenses/:id/review

Auth: Bearer JWT required
Roles: manager, hr, admin
Headers: Content-Type: application/json | Authorization: Bearer <token>
Body (JSON):
{
 "decision": "approved",
 "note": "Valid receipt"
}
Note: High-value (>=50000) needs HR/Admin

10. Assets /api/assets

GET /api/assets/me

Auth: Bearer JWT required

Roles: staff

Headers: Authorization: Bearer <token>

GET /api/assets/team

Auth: Bearer JWT required

Roles: manager, hr, admin

Headers: Authorization: Bearer <token>

POST /api/assets/assign

Auth: Bearer JWT required

Roles: manager, hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "asset": "<assetId>",
  "employee": "<userId>",
  "notes": "New hire laptop"
}
```

PATCH /api/assets/assignments/:id/return-request

Auth: Bearer JWT required

Roles: assignment owner

Headers: Authorization: Bearer <token>

PATCH /api/assets/assignments/:id/return

Auth: Bearer JWT required

Roles: hr, admin

Headers: Authorization: Bearer <token>

GET /api/assets

Auth: Bearer JWT required

Roles: staff

Headers: Authorization: Bearer <token>

Query: ?status=available

POST /api/assets

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "name": "MacBook Pro 14",
  "assetTag": "AST-001",
  "category": "laptop",
  "status": "available",
  "value": 350000
}
```

PATCH /api/assets/:id

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{ "status": "maintenance", "notes": "Battery issue" }
```

11. Recruitment /api/recruitment

GET /api/recruitment/jobs

Auth: Optional Bearer JWT

Headers: Authorization: Bearer <token> (optional)

Query: ?status=active

Note: Public sees active jobs only. HR/Admin with token can filter.

POST /api/recruitment/jobs

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "title": "Frontend Developer",
  "description": "Build RN + web UI",
  "department": "<deptId>",
  "branch": "<branchId>",
  "requirements": ["React Native", "2+ years"],
  "employmentType": "full-time",
  "location": "Lahore",
  "salaryRange": { "min": 80000, "max": 120000, "currency": "PKR" },
  "status": "active",
  "closesAt": "2026-08-31"
}
```

PATCH /api/recruitment/jobs/:id

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{ "status": "closed" }
```

DELETE /api/recruitment/jobs/:id

Auth: Bearer JWT required

Roles: hr, admin

Headers: Authorization: Bearer <token>

Note: Sets status to closed

POST /api/recruitment/jobs/:jobId/apply

Auth: Bearer JWT required

Roles: candidate

Headers: Content-Type: multipart/form-data | Authorization: Bearer <token>

Body (multipart/form-data):

coverLetter: I am interested...

resume: <pdf/doc file>

GET /api/recruitment/applications/me

Auth: Bearer JWT required

Roles: candidate

Headers: Authorization: Bearer <token>

GET /api/recruitment/applications

Auth: Bearer JWT required

Roles: hr, admin

Headers: Authorization: Bearer <token>

Query: ?job=&status=

PATCH /api/recruitment/applications/:id/status

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "status": "shortlisted",
  "notes": "Strong portfolio"
}
```

Note: status: applied | shortlisted | interview | hired | rejected

POST /api/recruitment/applications/:id/interviews

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "scheduledAt": "2026-08-05T10:00:00.000Z",
  "mode": "online",
  "location": "Zoom link",
  "interviewers": [<managerUserId>],
  "notes": "Technical round"
}
```

PATCH /api/recruitment/interviews/:id

Auth: Bearer JWT required

Roles: candidate, hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "action": "cancel"
}
OR
{
  "action": "reschedule",
  "scheduledAt": "2026-08-06T11:00:00.000Z",
  "mode": "phone"
}
```

POST /api/recruitment/interviews/:id/feedback

Auth: Bearer JWT required

Roles: assigned interviewer / hr / admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "score": 8,
  "comments": "Good problem solving",
  "recommendation": "hire"
}
```

Note: recommendation: strong-hire | hire | no-hire | strong-no-hire

POST /api/recruitment/applications/:id/hire

Auth: Bearer JWT required

Roles: hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "role": "employee",
  "department": "<deptId>",
  "branch": "<branchId>",
  "manager": "<managerId>",
  "designation": "Junior Developer",
  "dateOfJoining": "2026-08-15"
}
```

Note: Converts candidate user to employee + employeeId

GET /api/recruitment/interviews/me

Auth: Bearer JWT required

Roles: all roles

Headers: Authorization: Bearer <token>

12. Communication /api/communication

GET /api/communication/announcements

Auth: Bearer JWT required

Roles: all

Headers: Authorization: Bearer <token>

POST /api/communication/announcements

Auth: Bearer JWT required

Roles: manager, hr, admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "title": "Office closed Friday",
  "body": "Due to maintenance...",
  "audience": "all",
  "isPinned": true
}
```

Note: audience: all | department | team

POST /api/communication/messages

Auth: Bearer JWT required

Roles: all

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "recipient": "<userId>",
  "subject": "Leave question",
  "body": "Can I take leave next week?"
}
```

GET /api/communication/messages/inbox

Auth: Bearer JWT required

Roles: all

Headers: Authorization: Bearer <token>

GET /api/communication/messages/sent

Auth: Bearer JWT required

Roles: all

Headers: Authorization: Bearer <token>

PATCH /api/communication/messages/:id/read

Auth: Bearer JWT required

Roles: recipient

Headers: Authorization: Bearer <token>

13. Reports /api/reports

GET /api/reports/me

Auth: Bearer JWT required

Roles: staff

Headers: Authorization: Bearer <token>

Note: Personal KPI: attendance %, leave usage

GET /api/reports/team

Auth: Bearer JWT required

Roles: manager, hr, admin

Headers: Authorization: Bearer <token>

GET /api/reports/hr

Auth: Bearer JWT required

Roles: hr, admin

Headers: Authorization: Bearer <token>

Note: Hiring funnel, employee counts, payslips

14. Admin /api/admin

GET /api/admin/users

Auth: Bearer JWT required

Roles: admin only

Headers: Authorization: Bearer <token>

Query: ?role=employee&includeDeleted=false

PATCH /api/admin/users/:id/status

Auth: Bearer JWT required

Roles: admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{ "isActive": false }
```

POST /api/admin/users/:id/force-password-reset

Auth: Bearer JWT required

Roles: admin

Headers: Authorization: Bearer <token>

Note: Audit flag — user uses forgot-password flow

PATCH /api/admin/users/:id/role

Auth: Bearer JWT required

Roles: admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{ "role": "manager" }
```

DELETE /api/admin/users/purge-deleted

Auth: Bearer JWT required

Roles: admin

Headers: Authorization: Bearer <token>

Note: Permanently deletes soft-deleted users

GET /api/admin/settings

Auth: Bearer JWT required

Roles: admin

Headers: Authorization: Bearer <token>

PUT /api/admin/settings

Auth: Bearer JWT required

Roles: admin

Headers: Content-Type: application/json | Authorization: Bearer <token>

Body (JSON):

```
{
  "key": "salaryCycle",
  "value": { "day": 28 },
  "description": "Monthly payroll day"
}
```

GET /api/admin/audit-logs

Auth: Bearer JWT required

Roles: admin

Headers: Authorization: Bearer <token>

Query: ?limit=100

15. Postman / App tips

1. Always send role with auth endpoints (same role selected in the RN app)
2. Login !' copy data.token and read data.user.role for navigation
3. In every protected request set Header:
Authorization: Bearer <token>
4. For file uploads use form-data (not raw JSON)
5. IDs are MongoDB ObjectIds (24 hex chars)
6. Dates: ISO strings e.g. 2026-07-28 or 2026-07-28T09:00:00.000Z
7. Forgot password: forgot-password !' verify-otp !' reset-password (use otp from dev response)

Example login success:

```
{
```

```
"success": true,  
"message": "Login successful",  
"data": {  
  "user": { "_id": "...", "role": "hr", "name": "...", "email": "..."},  
  "token": "eyJhbGciOi..."  
}
```

Example role mismatch (403):

```
{  
  "success": false,  
  "message": "This account is registered as 'employee'. Please select that role to login."  
}
```